

Information Security Policy

ABC Solutions

ISO/IEC 27001:2022 Information Security Management System

Field	Details
Document Title	Information Security Policy
Organization	ABC Solutions
Document Owner	Information Security Manager
Version	1.0
Classification	Internal
Effective Date	08 September 2026
Review Frequency	Annual
Approved By	Management

Table of Contents

Document Control	3
Version History	3
Purpose.....	3
Scope.....	3
Information Security Policy Statement.....	3
Roles and Responsibilities.....	4
Information Security Principles.....	4
Information Security Risk Management.....	4
Access Control	5
Information Security Awareness and Training	5
Information Security Incident Management	5
Business Continuity and Information Backup	5
Compliance with Legal, Regulatory, and Contractual Requirements	6
Monitoring and Review.....	6
Policy Exceptions	6
Policy Review and Approval.....	6

Document Control

Version History

Version	Date	Description	Approved By
1.0	08 September 2026	Initial Release	Management

Purpose

The purpose of this Information Security Policy is to establish the overall direction, principles, and commitment of ABC Solutions for protecting its information assets and maintaining an effective Information Security Management System (ISMS).

This policy provides a framework for establishing information security objectives, managing information security risks, implementing appropriate controls, meeting applicable requirements, and continually improving the ISMS in accordance with ISO/IEC 27001:2022.

Scope

This Information Security Policy applies to all employees, contractors, authorised third parties, information assets, business processes, applications, systems, networks, and cloud services that fall within the defined ISMS scope of ABC Solutions.

All personnel and relevant third parties within the scope are expected to comply with this policy and applicable supporting information security policies, standards, procedures, and controls.

Information Security Policy Statement

ABC Solutions is committed to protecting the confidentiality, integrity, and availability of information and to managing information security risks through an effective Information Security Management System.

To support this commitment, ABC Solutions shall:

- Protect information from unauthorised access, disclosure, modification, loss, or destruction.
- Identify, assess, and treat information security risks using an established risk management process.
- Implement appropriate administrative, technical, and physical security controls.
- Comply with applicable legal, regulatory, contractual, and information security requirements.
- Establish and monitor appropriate information security objectives.
- Promote information security awareness among employees and relevant third parties.
- Maintain appropriate processes for identifying, reporting, and responding to information security incidents.
- Continually improve the suitability, adequacy, and effectiveness of the ISMS.

Roles and Responsibilities

Information security is a shared responsibility across ABC Solutions. Specific responsibilities are assigned as follows:

Role	Responsibility
Top Management	Provide leadership, approve the Information Security Policy, support the ISMS, and ensure appropriate resources are available.
Information Security Manager	Coordinate the ISMS, monitor information security risks and controls, maintain security documentation, and report relevant security matters to management.
IT Team	Implement and maintain technical security controls, systems, networks, access controls, backups, and security configurations.
Employees and Contractors	Comply with applicable security policies and procedures, protect organisational information, and report suspected security incidents.
Risk Owners	Monitor assigned information security risks and approve appropriate risk treatment and residual risk decisions.

Information Security Principles

ABC Solutions shall manage information security in accordance with the following fundamental principles:

- **Confidentiality:** Information shall **be accessible** only to authorised individuals and entities.
- **Integrity:** Information shall be protected against unauthorised or improper modification or destruction.
- **Availability:** Information and supporting systems shall be available to authorised users when required.
- **Least Privilege:** Users shall be provided only the access necessary to perform their assigned responsibilities.
- **Need to Know:** Access to information shall be limited to individuals who require it for legitimate business purposes.
- **Defence in Depth:** Multiple layers of security controls shall be applied where appropriate to reduce information security risks.

Information Security Risk Management

ABC Solutions shall establish and maintain a systematic process for identifying, analysing, evaluating, and treating information security risks that may affect the confidentiality, integrity, or availability of information.

Information security risks shall be assessed using defined risk criteria and treated based on their assessed level and the organisation's risk treatment decisions. Appropriate controls shall be selected and implemented to reduce risks to acceptable levels.

Risk assessments and risk treatment activities shall be reviewed periodically and when significant changes occur to the organisation, its technology, business processes, threat environment, or applicable requirements.

Access Control

Access to ABC Solutions' information, systems, applications, and other information assets shall be granted based on legitimate business requirements and appropriate authorisation.

Access rights shall follow the principles of least privilege and need to know. User access shall be approved, periodically reviewed, modified when responsibilities change, and removed promptly when access is no longer required.

Privileged access shall be restricted to authorised personnel and subject to additional security controls. Appropriate authentication mechanisms, including multi-factor authentication where required, shall be implemented based on security and business requirements.

Information Security Awareness and Training

ABC Solutions shall ensure that employees and relevant contractors receive appropriate information security awareness and training based on their roles and responsibilities.

Personnel shall be made aware of applicable information security policies, their responsibilities for protecting organisational information, common security threats, and the procedures for reporting suspected information security incidents.

Information security awareness and training activities shall be conducted periodically, and appropriate records of participation or completion shall be maintained as evidence.

Information Security Incident Management

ABC Solutions shall establish and maintain appropriate processes for identifying, reporting, assessing, responding to, and managing information security incidents.

Employees, contractors, and relevant third parties shall promptly report suspected or actual information security events and incidents through established reporting channels.

Information security incidents shall be investigated and handled according to their nature and severity. Appropriate records shall be maintained, and lessons learned from incidents shall be used to improve security controls and reduce the likelihood or impact of recurrence.

Business Continuity and Information Backup

ABC Solutions shall implement appropriate measures to support the availability and resilience of information systems and services during disruptions and information security incidents.

Critical information and systems shall be backed up according to defined business and security requirements. Backups shall be appropriately protected and retained to support recovery when required.

Backup restoration and relevant recovery arrangements shall be tested periodically to verify that information and critical services can be recovered within appropriate business requirements.

Compliance with Legal, Regulatory, and Contractual Requirements

ABC Solutions shall identify and comply with applicable legal, regulatory, contractual, and other information security requirements relevant to its operations, information assets, and services.

Relevant requirements shall be reviewed periodically and when significant changes occur to applicable laws, regulations, contracts, business activities, or information security obligations.

Appropriate controls and records shall be maintained to support compliance and provide evidence that applicable information security requirements are being addressed.

Monitoring and Review

ABC Solutions shall monitor and evaluate the performance and effectiveness of its Information Security Management System and relevant information security controls.

Information security performance shall be reviewed through appropriate monitoring and measurement activities, risk reviews, internal audits, management reviews, and other relevant assessments.

Identified weaknesses, nonconformities, and opportunities for improvement shall be addressed through appropriate corrective actions and continual improvement activities.

Policy Exceptions

Any exception to this Information Security Policy shall be formally documented, justified, risk-assessed, and approved by appropriate management before implementation.

Approved exceptions shall specify the reason for the exception, affected systems or processes, responsible owner, applicable compensating controls, approval period, and review or expiry date.

Policy exceptions shall be periodically reviewed to determine whether they remain necessary and whether the associated information security risks remain acceptable.

Policy Review and Approval

This Information Security Policy shall be reviewed at planned intervals and when significant changes occur to ABC Solutions' business operations, information security risks, technology, legal or regulatory requirements, or the Information Security Management System (ISMS).

Changes to this policy shall be appropriately reviewed, approved, documented, and communicated to relevant personnel and interested parties as appropriate.

Field	Details
Policy Owner	Information Security Manager
Approved By	Management
Effective Date	08 September 2026
Next Review Date	08 September 2027
Review Frequency	Annual